

Отчет по аудиту безопасности

1. SQL-инъекции

- **Анализ:** Во всех файлах для работы с БД используется PDO и подготовленные выражения (`prepare`, `execute`). Это защищает от классических инъекций.
- **Метод защиты:** Использование плейсхолдеров (?) для разделения логики запроса и данных.
- **Пример из кода:**

```
$stmt = $db->prepare("SELECT password FROM admins WHERE login = ?");  
$stmt->execute([$ _SERVER['PHP_AUTH_USER']]);
```

2. XSS

- **Анализ:** В `index.php` и `admin.php` большинство данных фильтруется через `htmlspecialchars()`. Однако в `index.php` имя пользователя `$_SESSION['login']` и некоторые сообщения об ошибках выводятся напрямую. Если подменить сессию или перехватить вывод, это позволит внедрить скрипт.
- **Метод защиты:** Тотальное экранирование любого вывода из внешних источников (БД, Сессии, Куки).
- **Пример исправления:**

```
// Было: Вы вошли как: <?php echo $_SESSION['login']; ?>  
// Стало:  
Вы вошли как: <b><?php echo htmlspecialchars($_SESSION['login']); ?></b>
```

3. Information Disclosure

- **Анализ:** В файлах `form.php` и `login.php` ошибки БД выводятся пользователю через `die($e->getMessage())`. При сбое подключения виден логин БД, структуру таблиц и локальные пути сервера.
- **Метод защиты:** Логирование ошибок в системный файл и вывод нейтрального сообщения пользователю.
- **Пример исправления:**

```
catch (PDOException $e) {  
    error_log($e->getMessage());  
    exit('Внутренняя ошибка сервера. Попробуйте позже.');
```

4. CSRF

- **Анализ:** Приложение не проверяет источник запроса. Можно создать вредоносную страницу, которая от лица авторизованного админа удалит записи (через GET `?delete=...`) или изменит данные пользователя (через POST в `form.php`).
- **Метод защиты:** Внедрение уникального токена (CSRF-token) в сессию и проверку его наличия в каждом POST/GET запросе, изменяющем данные.
- **Пример реализации:**

```
// В форме:  
<input type="hidden" name="token" value="<?= $_SESSION['csrf_token'] ?>">  
// В обработчике:  
if ($_POST['token'] !== $_SESSION['csrf_token']) die('Invalid CSRF Token');
```